Unit 7. Database Security **[5hrs]**

7.1 Security requirements

7.2 Reliability and integrity

7.3 Sensitive data

7.4 Inference

7.4 Multilevel database

7.5 Proposals for multilevel security

Introduction: =>

Data: Data refers to raw facts, figures, or information that can be processed and analyzed to derive meaning or insights.

Database: A database is an organized collection of structured data, typically stored electronically, that can be accessed, managed, and updated.

Database Security: Database security involves the use of tools, processes, and policies to protect a database from unauthorized access, breaches, or malicious activities, ensuring data confidentiality, integrity, and availability.

Database security is the processes, tools, and controls that secure and protect databases against accidental and intentional threats. The objective of database security is to secure sensitive data and maintain the **confidentiality, availability, and integrity** of the database.

Why do we use database security?

Database security programs are designed to protect not only the data within the database, but also the data management system itself, and every application that accesses it, from misuse, damage, and intrusion.

7.1 Security requirements: =>

The various requirement in database security are as follows :=>

- Separate Database Servers and Web Servers.
- Database Encryption at Rest and In Transit. ("**Database Encryption at Rest and In Transit**" refers to encryption methods used to protect data in a database during two different stages: when it is stored (at rest) and when it is being transmitted (in transit).
- Use Strong Authentication.
- Continuously Discover Sensitive Data.
- Revoke Privileges Continuously. [revoking privileges continuously is a security practice aimed at limiting access to sensitive data and operations by constantly evaluating and adjusting user permissions]
- Deploy Physical Database Security.

- Ensure Database User Accounts Are Secure.
- Monitor Database Activity.

1. **Separate Database Servers and Web Servers:** => By separating database servers from web servers, you reduce the attack surface. If the web server is compromised, the attacker doesn't automatically gain access to the database server.
2. **Database Encryption at Rest and in Transit:** => Encrypting data both at rest (stored data) and in transit (data being transmitted) ensures that even if data is intercepted or accessed in unauthorized manner, it cannot be read without the encryption keys.
3. **Use Strong Authentication**: => Strong authentication mechanisms ensure that only authorized users can access the database.
4. **Continuously Discover Sensitive Data**: => Knowing where sensitive data is stored helps in focusing security measures and compliance efforts.
5. **Revoke Privileges Continuously:** => Regularly updating and revoking unnecessary privileges reduces the risk of insider threats and limits potential damage from compromised accounts.
6. **Deploy Physical Database Security**: => Physical security measures protect the database servers from physical tampering, theft, or damage.
7. **Ensure Database User Accounts Are Secure** :=> Protecting database user accounts from unauthorized access is critical to maintaining database security.
8. **Monitor Database Activity**: => Monitoring database activity helps detect and respond to suspicious behavior in real time.
9. **Regular Patching and Updates:** Keep database software and underlying systems up to date with the latest security patches.
10. **Backup and Recovery:** Ensure regular backups are taken and securely stored. Test recovery procedures to ensure data can be restored in case of a security incident.

7.2 Reliability and integrity

Database reliability is a measure of accuracy and consistency of data. Given the strategic importance of databases as part of organizations' information system infrastructure, maintaining reliability is critical for effective utilization.

Database reliability is defined broadly to mean that the database performs consistently without causing problems. More specifically, it means that there is accuracy and consistency of data.

Data integrity is a concept and process that ensures the accuracy, completeness, consistency, and validity of an organization's data. By following the process, organizations not only ensure the integrity of the data but guarantee they have accurate and correct data in their database**.**

Integrity in cyber security: =>

Integrity in cyber security means data is complete, trustworthy and has not been modified or accidentally altered by an unauthorized user. The integrity of data can be compromised unintentionally by errors in entering data, a system malfunction, or forgetting to maintain an up-to-date backup.

Example of Data Integrity and Reliability in Database Security

Scenario: Healthcare Database

Tables:

a. Patients
b. Appointments

Data Integrity

➔ Primary Keys:

Patients Table: PatientID uniquely identifies each patient.

Appointments Table: AppointmentID uniquely identifies each appointment.

➔ Foreign Keys:

Appointments Table: PatientID references PatientID in the Patients table, ensuring that each appointment is linked to a valid patient.

➔ Data Integrity Measures:

- Primary Key Uniqueness: PatientID and AppointmentID are unique, ensuring no duplicates.
- Foreign Key Referential Integrity: PatientID in the Appointments table must match an existing PatientID in the Patients table, ensuring valid links between tables.

In Short: By using primary keys and foreign keys, this database setup ensures that data remains accurate, consistent, and reliable. Each appointment is linked to a valid patient, preventing data inconsistencies and ensuring the integrity and reliability of the healthcare database.

7.3 Sensitive data :=>

Sensitive data includes personal data but has a wider scope, which encompasses data that if disclosed could cause harm or adverse consequence

s for the individual concerned. Common examples of sensitive data include financial account information, health records, and trade union memberships.

The following data protection methods are some of the best ways that you can protect your sensitive data:

a. Take Control of Sensitive Data.
b. Encrypt Your Data.

c. Use a Password Manager.
d. Backup Your Data.
e. Ensure The Security of Physical Records and Devices.
f. Use a VPN on Public Wi-Fi.
g. Always Stay Up to Date.

What does VPN mean here?

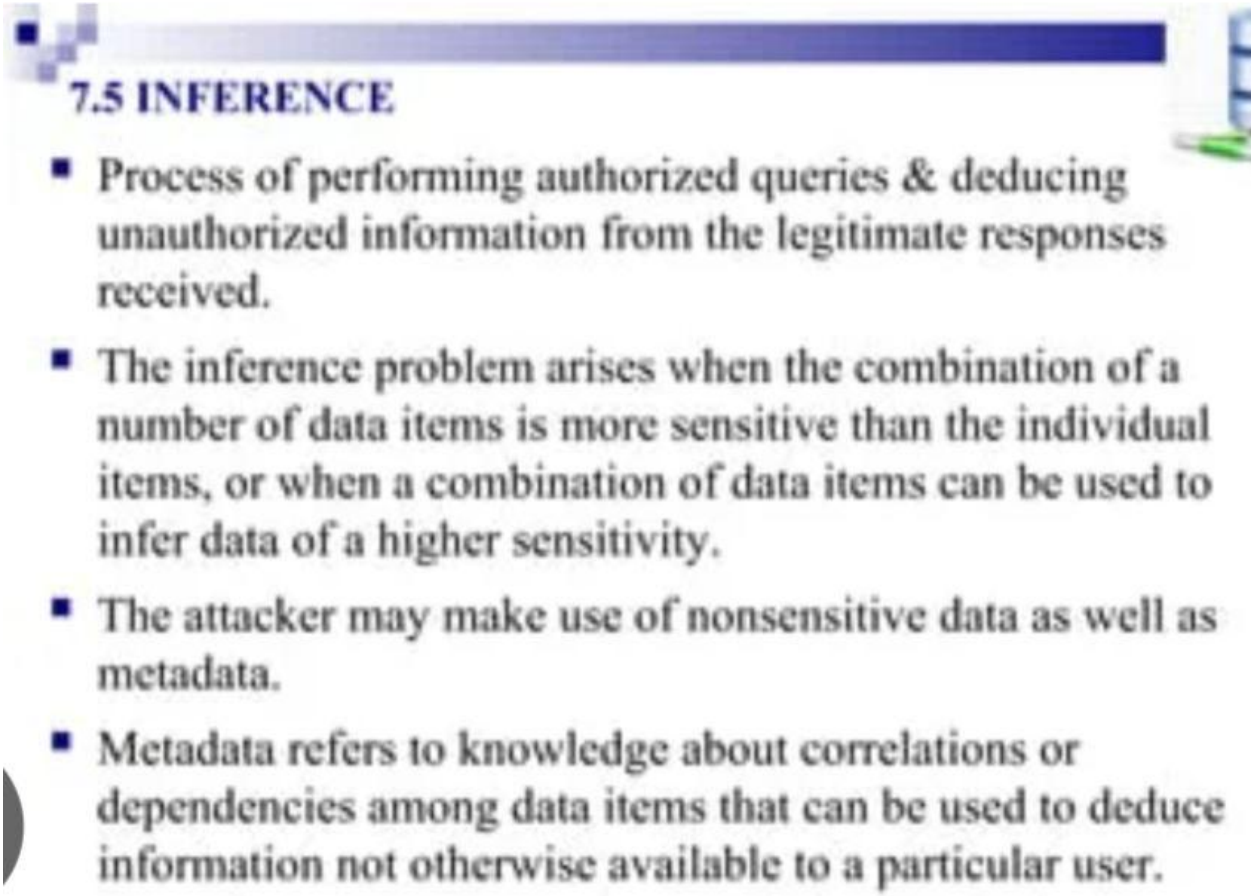
In this context, a VPN (Virtual Private Network) is a secure connection method that encrypts your internet traffic and routes it through a remote server, protecting your data from being intercepted on public Wi-Fi networks. Using a VPN on public Wi-Fi means that your online activities are shielded from potential threats like hackers, ensuring privacy and security even when using unsecured networks.

7.4 Inference: =>

Inference is a method of deducing sensitive information from non- sensitive data through a series of logical or statistical analyses. Inference attacks can be carried out by an attacker who has access to a database that contains both sensitive and non-sensitive data.

OR

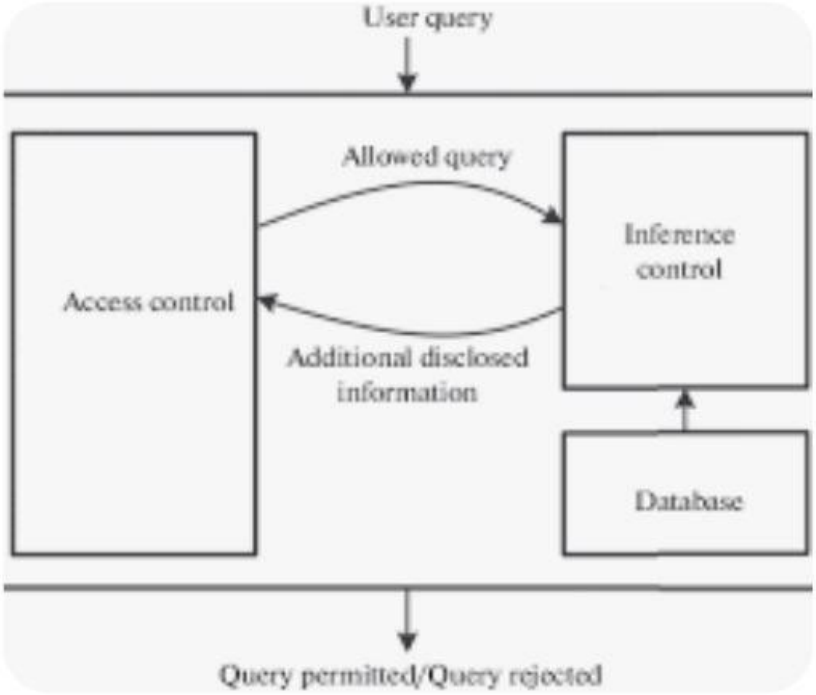
Inference is figuring out sensitive information by analyzing non-sensitive data. Attackers can use patterns and connections in the data they can access to deduce confidential details that they are not directly allowed to see. This process, called an inference attack, allows them to uncover hidden information without directly accessing it.



Inference attack

:=>

An inference attack is a data mining technique in which data is inferred from partial information. By analyzing large amounts of data, an attacker can illegally gain knowledge about a database or its contents without actually accessing it. Data is considered trivial only if nothing can be inferred from it.



This block diagram illustrates a secure query processing system involving **access control** and **inference control**. When a **user query** is received, it first passes through the **access control** module, which determines whether the user is authorized to access the requested data. If allowed, the query is then checked by the **inference control** system to ensure that no sensitive information can be inferred from the results. Based on this analysis, the query is either **permitted or rejected**, ensuring both direct and indirect data protection.

WAYS TO CONTROL INFERENCE ATTACK: =>

Although inference cannot be fully prevented, there are some ways to control and manage the issue. These methods are performed by professionals and are divided into three sub-disciplines: =>

a. **Microdata Protection:** =>
   Professionals create new tables that look different from the original ones, either by masking the real data or creating fake data to hide confidential information

b.

Tabular data protection: =>They present data using average values or ranges instead of specific details used by governments and agencies to conceal data.

c.

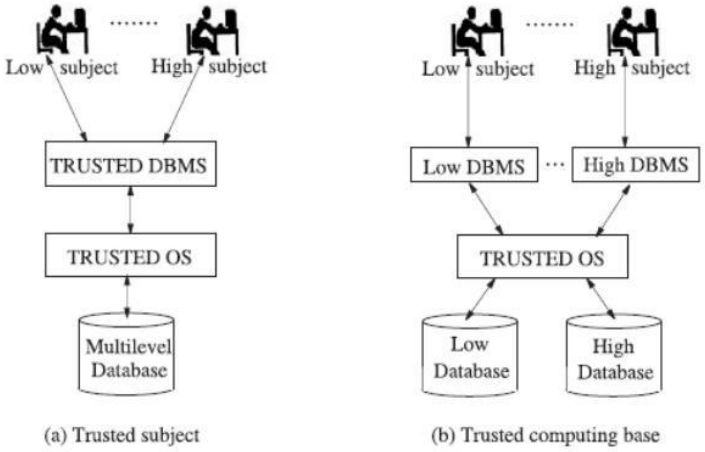
Query able data protection: =>Numeric data is replaced with descriptive data, requiring more effort to understand, often using open-ended questions to prevent revealing sensitive numeric data.

7.4 Multilevel database:=>

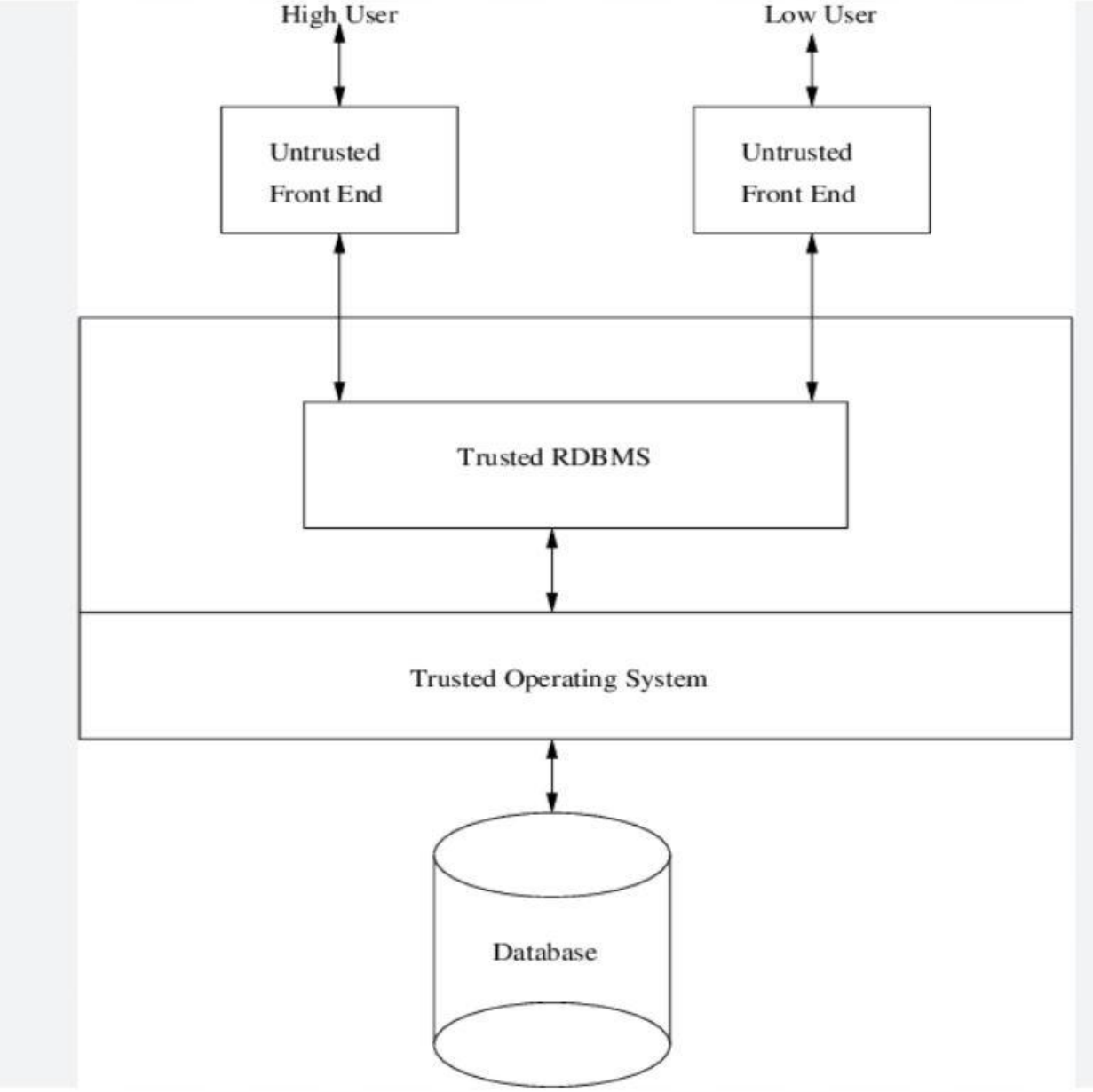
A multilevel database system (MDBMS) supports the application of a multilevel policy for regulating access to the database objects. A **multilevel database** is a type of database designed to store and manage data at different security levels, ensuring that users with different clearance levels can only access the data appropriate to their level. In this system, a **high user** has access to data at both higher and lower security levels, while a **low user** can only access data at their own lower security level, without visibility into higher-level data.

Multilevel DBMSs Architecture

- Trusted subject. The DBMS itself must be trusted to ensure mandatory policy
- Trusted Computing Base: Data are partitioned in different databases, one for each level



(a) Trusted subject (b) Trusted computing base



IMPORTANCE of Multilevel database: =>

- Multilevel database security is crucial for protecting sensitive data by applying different security measures based on data sensitivity.
- It ensures compliance with regulations and reduces the risk of widespread data exposure in case of a breach.
- This approach allows for granular access control, restricting data access to authorized users only.
- Additionally, it enhances data integrity and supports detailed auditing and monitoring to detect and address potential security issues.

7.5 Proposals for multilevel security:=>

The proposal for implementing multilevel security includes following: =>

1. **Partitioning:** The database is segmented into multiple databases or tables, each with a specific sensitivity level. For example, you might have one database for public information and another for confidential data. This separation ensures that access controls and security measures can be tailored to the sensitivity of each segment.

2. **Encryption**: Each segment or level of data is encrypted using different encryption keys. For instance, data with high sensitivity could be encrypted with a stronger, more complex key than data with lower sensitivity. This way, even if an attacker compromises one encryption key, they still cannot access data encrypted with a different key.

3. **Integrity Lock ("spray paint"):** This involves using mechanisms like cryptographic hashes or digital signatures to ensure data integrity. When data is created or modified, a hash value (a unique string generated by a hash function) is calculated and stored. If the data is altered, the hash value will change, indicating that the data has been tampered with. This “spray paint” helps in detecting unauthorized modifications.

4. **Sensitivity Lock**: This approach uses a combination of access controls and labels to secure data. Each piece of data is tagged with a sensitivity label and a unique identifier. Access controls are configured so that only users or processes with the appropriate permissions (corresponding to the sensitivity level) can access or manipulate the data. This helps in managing access based on the sensitivity of the data.

In summary, these methods work together to secure data by separating it into different sensitivity levels, using distinct encryption keys, ensuring data integrity, and implementing fine-grained access controls.